

Digital Transformation of Security Standards: Requirements Extraction using Large Language Models

Miltiadis Siavvas*, Georgia Xanthopoulou, Ilias Kalouptoglou, Dionysios Kehagias, and Dimitrios Tzovaras
Centre for Research and Technology Hellas, Thessaloniki, Greece
siavvasm@iti.gr, georgixv@iti.gr, iliaskalou@iti.gr, diok@iti.gr, Dimitrios.Tzovaras@iti.gr

*corresponding author

Abstract—Compliance with international security standards is essential for ensuring the security of information systems, and thereby their dependability and trustworthiness. Compliance evaluation is performed by experts who check whether critical security requirements (i.e., criteria), which have been extracted from standard documents, are met by the system. The extraction of security requirements from the standards documents is a tedious and labor-intensive task that is typically performed manually by experts. In order to facilitate the process, in the present paper we propose an approach utilizing Transformer-based models, specifically Large Language Models (LLMs), to automate the identification and extraction of these requirements, effectively transforming security standards into a comprehensive list of requirements. In particular, the proposed approach is based on fine-tuning pre-trained LLMs, including BERT, T5, and BART, on a domain-specific dataset constructed from real security standards in the downstream task of requirements identification and extraction. The capabilities of the approach are illustrated through representative examples.

Keywords—Cybersecurity, Security Standards, Transformer Architecture, Large Language Models

1. INTRODUCTION (PROBLEM STATEMENT)

Compliance with international security standards is crucial for modern information systems for enhancing their cybersecurity posture, thereby strengthening their dependability and trustworthiness. Compliance evaluation is performed by security experts (i.e., auditors) who check whether critical security criteria (i.e., requirements) that are expressed in the relevant standards are satisfied by the subject system. These requirements are expressed in the form of checklists that the experts have to complete, which are normally created by the experts, who have to manually go through the often lengthy and highly complex standards documents, in order to detect and extract the security criteria. This process is time-consuming, effort-demanding, and prone to human error, highlighting the need for more efficient and accurate methods to identify and extract requirements from standard documents.

Although several techniques chiefly from the field of natural language processing (NLP) have been studied for enabling the extraction of requirements from textual descriptions, none of them achieved sufficient accuracy and automation [1], [2]. In fact, many of these methods are limited in their ability to

fully understand the nuanced language of security standards, resulting in incomplete or inaccurate extraction of security requirements. Recently, the proposition of the Transformer-based Large Language Models (LLMs), which have demonstrated remarkable human-like capabilities in language understanding and processing, has created new opportunities for automating the process of digital transformation of security standards.

To this end, in the present paper, we discuss how LLMs could be leveraged for automating the digital transformation of security standards into lists of security requirements, and propose a concrete approach to automate the identification and extraction of security requirements from security standard documents. The proposed approach is based on fine-tuning popular LLMs, including BERT, GPT, and BART, in the downstream task of security requirements identification and extraction, based on a domain-specific dataset constructed from information retrieved from actual standards. Real-world examples are used to illustrate the approach.

2. PROPOSED SOLUTION

Our objective is to provide an artificial intelligence (AI) mechanism that will take as input fragments of the standard document (or even the complete document) and automatically identify and extract the main requirements that are expressed in the standard. The idea is to adapt an LLM and teach it how to detect and extract requirement sentences from the textual descriptions found in security standards.

The high-level overview of the proposed approach is illustrated in Figure 2. As can be seen by Figure 2, the overall approach consists of four different steps, which are: (i) Dataset Construction, (ii) Data Preparation, (iii) Model Selection, and (iv) Model Execution (Inference). The first three steps are responsible for building the Requirements Identification and Extraction (RIE) model, whereas the last step corresponds to the actual utilization of the produced model in practice.

Dataset Construction: The first step of our approach is the construction of a domain-specific dataset, which is required for fine-tuning the selected LLMs. For this purpose, we gathered information from two security standards, i.e., ISO/IEC 27001 and NIST SP 800 53. Particularly, we extracted text from the selected standards and created pairs of actual paragraphs (context) from the standard and the security requirements (sentences) that those paragraphs contained. We created a dataset comprising 500 paragraphs, along with their sentences.

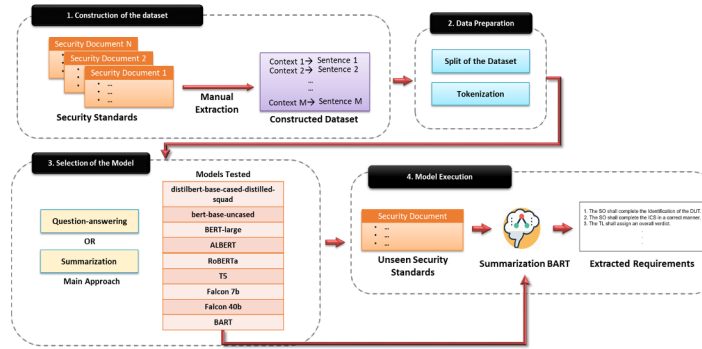


Figure 1. The high-level overview of the proposed approach

Dataset Preparation: The next step of the approach is data preparation, which is responsible for preparing the data for the model selection process. We split our dataset into training, validation, and testing sets, and we utilized the first two for fine-tuning the LLMs and selecting the best model, whereas the latter was utilized for evaluating the model's performance on unseen data. We also tokenized the data samples to generate word sequences, which is the required format for LLMs.

Model Selection: The model selection step involves fine-tuning popular pre-trained LLMs in the downstream task of security requirements identification and extraction based on the constructed domain-specific dataset. For the construction of our models, we examined two different training approaches: (i) Question-Answering and (ii) Summarization. We fine-tuned several pre-trained LLMs, including BERT, DistilBERT, ALBERT, RoBERTa, T5, Falcon, and BART, for the specific task of requirements identification and extraction. Despite the relatively small dataset, the LLM models showed good performance, with BART demonstrating the best results.

Model Execution: During the model execution (i.e., inference) step, the best-performing model (here BART) is used to identify and extract security requirements from unseen standards. To illustrate the effectiveness of our approach and facilitate better understanding, we provide real-world examples using text fragments from security standards and demonstrate how the fine-tuned models (particularly BART) extract the specified requirements. More specifically, in Figure 2, we present an example from a textual fragment retrieved from a security standard that was not used during the training phase (i.e., ETSI TS 103 701) containing two security requirements within the text (marked in red) and the output of the model. As can be seen by Figure 2, the model is able to extract the two underlying requirements, by filtering out irrelevant text.

The aforementioned example is representative of the purpose of the RIE models, as well as of the benefits that they may provide in automating the labor-intensive process of manually extracting requirements from standards. Highly effective RIE models are expected to greatly streamline the process, and highly reduce the time and effort required to perform it.

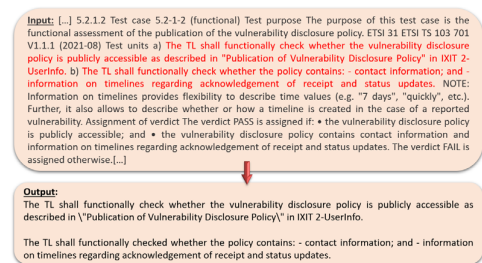


Figure 2. Example of requirements extraction from a security standard

3. CONCLUSION

In the present paper, we presented our ongoing work in deriving an approach for utilizing LLMs for automating the process of identifying and detecting security requirements from security standard documents, which is a highly time-consuming and effort-demanding task. The results that we achieved so far are promising, despite the small dataset that has been used, indicating the potential of LLMs in the RIE task and that with the future extension of the dataset the accuracy of the LLMs could be further enhanced. This work is part of the HorizonEU DOSS project, and, thus, during the culmination of the project a large requirements dataset will be constructed for building highly accurate and generalizable RIE models. Both the models and the dataset will be the main project outcomes.

ACKNOWLEDGMENT

The work reported in this paper has been partially funded by European Union's Horizon Europe Program through the DOSS project, Grant Number 101120270.

REFERENCES

- [1] Zhao L, Alhoshan W, Ferrari A, Letsholo KJ, Ajagbe MA, Chioasca EV, Batista-Navarro RT. Natural language processing for requirements engineering: A systematic mapping study. *ACM Computing Surveys*.
- [2] Umar MA, Lano K. Advances in automated support for requirements engineering: a systematic literature review. *Requirements Engineering*. 2024 Feb 3:1-31.